

CYBERSECURITY FOR PROFESSIONALS BOOTCAMP

TEAM-BASED LAB

Triaging SIEM Alerts and Simulating Incident Response

Week 7, Days 1–2 • Day 1 Individual • Day 2 Team

No software to install • No accounts to create • No cost

1. Before You Start

This lab runs on paper and in a spreadsheet. There is no system to log into, no console to learn, and no password to request. Everything you need is printed in this document.

That is deliberate. Tier 1 triage is a judgement skill, not a tool skill. You will learn the SIEM console itself in Week 8. Today is about whether you can look at an alert and make a call you can defend.

1.1 What you need

Item	Detail
A spreadsheet	Excel, Google Sheets or LibreOffice Calc. Your triage log lives here.
A document editor	For your escalation notes and, on Day 2, your after-action report.
A calculator	Your phone is fine. You will do distance and time arithmetic on the impossible-travel alerts.
This document	Keep it open. Sections 4 and 5 are reference material you will use constantly.

There are no trick questions, but there are hard ones

Twenty alerts are in the queue. Roughly half should be closed and roughly half escalated, which is close to what a real Tier 1 shift looks like.

Two of them are genuinely ambiguous. Reasonable analysts could disagree. Those are not mistakes in the lab - they are the point of it, and how you handle them is worth more marks than the easy calls.

Several alerts look alarming and are benign. Several look routine and are not. Read the reference data in Section 4 before you judge anything.

1.2 Scope and ethics

Read this before you start

Every alert, log line, email address, account and transaction in this document is fabricated for the exercise. Meridian Trust Bank does not exist.

The external addresses and domains in the queue belong to the scenario. Do not visit them, look them up in a service that connects to them, or paste them into any site that performs live lookups.

Do not run any scanning or lookup tool against anything, anywhere, as part of this lab. There is nothing here that requires it.

2. The Scenario

You are a Tier 1 security analyst in Meridian Trust Bank's Security Operations Centre. It is Wednesday morning. The overnight queue has not been worked because the night analyst was pulled onto a separate incident, so twenty alerts are waiting for you.

Your shift lead wants the queue cleared by end of day, with a decision and a justification on every single alert.

2.1 How a tiered SOC works

Tier	What they do	What they hand on
Tier 1 - Monitoring and Triage	Works the alert queue. Applies runbooks. Decides close or escalate. Does not investigate deeply and does not take remediation action.	An escalation note to Tier 2, or a documented closure.
Tier 2 - Investigation	Takes escalations and investigates properly: pulls more data, correlates across systems, confirms or disproves the Tier 1 suspicion.	A confirmed incident to Tier 3, or a closed investigation.
Tier 3 - Hunt and Incident Response	Runs full incident response, hunts for related activity, coordinates containment and remediation.	A resolved incident and an after-action report.

The two ways a Tier 1 analyst fails

Escalating everything. If you escalate all twenty alerts, Tier 2 drowns and stops trusting your judgement. The queue exists precisely so that somebody filters it.

Closing something real. A single wrongly closed alert can be the one that mattered, and nobody will ever know it was wrong until the incident surfaces weeks later.

The job is holding both of those in mind at once. Your justification is what protects you either way - a closure with sound recorded reasoning is defensible even when it later turns out to be wrong.

3. How to Work Through This Lab

3.1 Time plan

Session	Section	What you are doing	Guide time
Day 1	4	Read the reference data before you touch the queue	30 minutes
Day 1	5	Read the four runbooks	45 minutes
Day 1	6	Work the twenty-alert queue	3 to 4 hours
Day 1	7	Write your escalation notes	1 hour
Day 2	8	Team kickoff and role assignment	30 minutes
Day 2	9	Investigation	2 hours
Day 2	10	Containment and remediation	1 to 2 hours
Day 2	11	Team after-action report	1 to 2 hours

3.2 Set up your triage log first

Create a spreadsheet with these columns before you read a single alert. Working the queue without a log is how analysts lose track of what they have already decided.

Column	What goes in it
Alert ID	MTB-A01 through MTB-D05
Type	Failed login, impossible travel, BEC indicator, or wire transfer
Decision	CLOSE or ESCALATE
Confidence	High, medium or low. Be honest.
Justification	Why. One or two sentences citing the specific detail that decided it.
Runbook step	Which runbook criterion you applied
Linked alerts	Any other alert in the queue you think is related

The Linked alerts column is the one people skip

Alerts arrive one at a time, in separate categories, often hours apart. Attacks do not.

Fill that column in as you go. If you finish the queue and it is completely empty, go back and look again.

3.3 What a good justification looks like

Standard	Example
Not acceptable	Looks fine. Closing.
Passing	Closing. The failed logins came from the user's own corporate IP and succeeded on the eighth attempt, which looks like a forgotten password.
Strong	Closing with high confidence. Seven failures then a success for cwalsh, all from 10.50.1.31, which the directory in Section 4.2 confirms is her assigned workstation. The sequence ran 08:41 to 08:44 on a Tuesday, inside business hours. The quarterly password rotation completed the previous day per Section 4.5, which makes a forgotten password the most likely explanation. Failed Login Runbook closure criterion 2 applies. No escalation, but I have noted it in case the same account appears again this week.

The pattern to copy

State the decision and your confidence. Name the specific evidence and where you got it. Say what ordinary explanation fits. Cite the runbook criterion. Note anything that would change your mind.

Five sentences. Every alert in your log should read like that.

4. Reference Data

Read this section before you work the queue. Most of the alerts cannot be decided correctly without it, and several look completely different once you have.

4.1 Meridian Trust at a glance

Item	Detail
Headquarters	Pittsburgh, Pennsylvania. All offices are in the Pittsburgh metro area.
Business hours	07:00 to 19:00 Eastern, Monday to Friday. Treasury Operations runs 07:00 to 17:00.
Wire cut-off	17:00 Eastern. Wires initiated after cut-off queue for the next business day.
Dual approval	Any outbound wire over 25,000 US dollars requires a second approver.
Today	Wednesday. The queue covers Monday night through this morning.

4.2 Staff directory (extract)

Account	Name and role	Assigned workstation	Notes
cwalsh	Carla Walsh, Retail Operations	10.50.1.31	-
dkoenig	Daniel Koenig, Infrastructure, domain admin	10.50.1.52	On approved leave all week
mnguyen	Minh Nguyen, Branch Support	10.50.1.44	New phone enrolled in MDM on Monday
rpatel	Rhea Patel, Credit Risk	10.50.1.60	-
jhaddad	Joseph Haddad, Commercial Lending	10.50.1.63	Approved travel, Miami conference, Tue to Fri
lbrennan	Liam Brennan, Data Services	10.50.1.71	Remote worker, uses corporate VPN daily
tokafor	Thomas Okafor, Treasury Operations	10.50.1.58	Authorised wire initiator
sgrigsby	Sara Grigsby, Audit	10.50.1.66	-
bfoster	Brian Foster, Marketing	10.50.1.80	-
dkessler	Diane Kessler, Chief Financial Officer	10.50.1.12	-
rharper	Ray Harper, Accounts Payable	10.50.1.49	Authorised payee administrator

4.3 Known network ranges

Range or address	What it is
10.50.1.0/24	Corporate workstation subnet, Pittsburgh offices
10.50.2.0/24	Server subnet
198.51.100.0/24	Meridian Trust corporate VPN egress. Physically located in a Columbus, Ohio datacentre. All remote-worker traffic appears to originate here.

Range or address	What it is
203.0.113.14	Meridian Trust mail gateway outbound address

The VPN egress range is the single most useful fact in this section

A remote worker sitting in their kitchen in Pittsburgh will appear to log in from Columbus, Ohio, because that is where the VPN traffic leaves Meridian Trust's network.

At least one alert in the queue looks like impossible travel purely because of this and is completely benign. Check every geolocation against this range before you escalate it.

4.4 Service accounts

Account	Purpose	Expected source	Expected behaviour
svc-backup-agent	Nightly backup job	10.50.2.25	Authenticates at 02:00 daily
svc-sql	Database service account	10.50.2.25	Authenticates continuously during business hours
svc-monitor	Estate monitoring agent	10.50.2.30	Checks in every 5 minutes

4.5 Recent change record

Date	Change	Reference
Monday	Quarterly password rotation completed for all Retail Operations staff	CHG-8841
Monday	Minh Nguyen issued a replacement phone, enrolled in MDM	CHG-8847
Two weeks ago	Backup agent credential rotated. Application team did not update the job.	CHG-8802, still open
Last Thursday	Payment of 250,000 US dollars to Harrow Logistics approved by CFO and Treasury lead	CR-2291

4.6 Approved wire beneficiaries (extract)

Beneficiary	Bank	First used	Typical amount
ADP Payroll Services	Wells Fargo, US	2019	128,000 to 132,000 US dollars, fortnightly
Harrow Logistics Ltd	Barclays, UK	2021	40,000 to 260,000 US dollars, irregular
Castlereagh Supply Co	PNC Bank, US	2022	80,000 to 95,000 US dollars, monthly
Delacroix Systems	Santander, ES	2023	15,000 to 22,000 US dollars, monthly

4.7 Travel time reference

You will need this for the impossible-travel alerts. Work out the distance, work out how fast the person would have had to move, and compare it against reality.

Mode	Realistic speed
Commercial airliner, cruise	500 to 560 miles per hour
Commercial flight, door to door	Add roughly 2 hours for airport time either side
Car on a motorway	65 to 75 miles per hour
Anything faster than about 600 miles per hour	Not physically possible for a person

Route from Pittsburgh	Great-circle distance
Columbus, Ohio	162 miles
Toronto, Canada	224 miles
Miami, Florida	1,014 miles
Bucharest, Romania	4,998 miles
Lagos, Nigeria	5,578 miles

5. The Runbooks

A runbook is the SOC's documented procedure for one alert type. It exists so that every analyst handles the same alert the same way, and so that a decision can be reviewed later against what the procedure actually said.

Apply them. If you close or escalate against a runbook you must say why, and that is a legitimate thing to do - runbooks do not cover everything. What is not acceptable is ignoring them silently.

5.1 Runbook: Failed Login

What the alert means

One or more authentication failures crossed a threshold. Thresholds are deliberately low, so most of these are benign.

What to check, in order

1. How many failures, over what period, and did any attempt eventually succeed?
2. Is the source address the user's own assigned workstation, the corporate VPN range, or somewhere else entirely?
3. One account or many? Failures spread across many accounts from one source is a different attack entirely.
4. Is the account privileged, a service account, or an ordinary user?
5. Does the timing fit the user's normal working pattern, and is there a change record that explains it?

Close if

- Fewer than 10 failures on a single ordinary account from that user's own workstation or the VPN range, followed by a success, inside business hours.
- A change record explains it, such as a password rotation or a new device enrolment.
- A service account failing from its expected source in its expected pattern, with a known open ticket.

Escalate if

- Failures span multiple accounts from a single source. This is password spraying and the count does not need to be high.
- The account is privileged and the attempt succeeded.
- The source is external or unrecognised.
- The activity falls outside the user's working pattern with no change record, and especially if the user is known to be away.

5.2 Runbook: Impossible Travel

What the alert means

The same account authenticated from two locations too far apart for the person to have travelled between them in the time available. The alert is generated automatically from IP geolocation, which is frequently wrong.

What to check, in order

1. Do the arithmetic yourself. Distance divided by elapsed time gives required speed. Compare against Section 4.7.
2. Is either address in the corporate VPN range? If so the geolocation is an artefact, not a movement.
3. Is there approved travel on record for this user?
4. What did the account do after the second login? A login is only half the story.
5. Was multi-factor authentication satisfied, and how - an approved push, or repeated prompts?

Close if

- The required speed is achievable by commercial flight and there is approved travel on record.
- One of the two addresses belongs to the corporate VPN egress range.
- The two locations are close enough that ordinary ground travel explains the gap.

Escalate if

- The required speed exceeds roughly 600 miles per hour. No person moves that fast.
- The second location is somewhere the user has never logged in from and there is no travel record.
- The account performed sensitive actions immediately after the second login.

5.3 Runbook: Business Email Compromise Indicator

What the alert means

Something in the mail environment matched a pattern associated with business email compromise. BEC is not malware. It is an attacker using a real or convincing mailbox to get money moved, and the technical footprint is very small.

What to check, in order

1. If a mailbox rule was created, what does it actually do? Rules that hide or delete messages are the single strongest BEC indicator there is.
2. Who created the rule, from what address, and at what time?
3. If a domain is involved, compare it character by character against the real one.

4. Does the display name match a real employee while the underlying address does not?
5. Did the message reach anyone, or was it blocked at the gateway?

Close if

- The activity is an ordinary mail feature used ordinarily, such as an out-of-office reply set by a user who is genuinely on leave.
- The message was blocked at the gateway, reached nobody, and the pattern is generic rather than targeted.

Escalate if

- A rule moves, deletes or marks as read any message matching financial keywords. Treat this as compromise until proven otherwise.
- A rule forwards mail to an address outside the bank.
- A lookalike domain is involved, whether or not the message was delivered.
- An executive or an authorised payment initiator is impersonated or targeted.

5.4 Runbook: Suspicious Wire Transfer**What the alert means**

An outbound transfer matched a fraud-monitoring rule. Meridian Trust moves large sums legitimately every day, so the amount alone tells you very little.

What to check, in order

1. Is the beneficiary on the approved list in Section 4.6, and is the amount consistent with its history?
2. If the beneficiary is new, when was it added and by whom?
3. If bank details on an existing beneficiary changed, how was the change requested and was it verified out of band?
4. Was it initiated inside business hours by an authorised initiator, and was dual approval satisfied?
5. Are there several transfers that look designed to stay under a threshold?

Close if

- Established beneficiary, amount within its normal range, initiated in hours by an authorised person.
- A change or approval record documents it, with the approvals recorded.

Escalate if

- A new beneficiary receives a significant first payment, particularly outside business hours.
- Bank details on an existing beneficiary changed shortly before a scheduled payment and the request arrived by email.
- Multiple transfers sit just under a reporting or approval threshold.
- The initiating account is the subject of any other alert in the queue.

That last criterion is doing a lot of work

Wire fraud almost never appears as a single wire alert. It appears as a login alert, then a mailbox alert, then a wire alert, hours apart, in three different categories, each one individually explainable.

Cross-check every wire alert against the account names in the rest of your queue before you decide.

6. Day 1: The Alert Queue

Twenty alerts. Work them in any order. Record a decision and a justification for every one.

6.1 Failed login alerts

```
MTB-A01  FAILED LOGIN THRESHOLD      Tue 08:41 EDT      Severity: Low
Account   : cwalsh
Source    : 10.50.1.31
Detail    : 7 consecutive authentication failures 08:41:02 to 08:43:48,
           followed by a successful authentication at 08:44:11.
MFA       : Satisfied, approved push, first prompt.
```

Field	Triage Log Entry
Alert ID	MTB-A01
Type	Failed Login
Decision	CLOSE
Confidence	High
Runbook Step	Failed Login Runbook — closure criteria 1 and 2
Linked Alerts	None identified

Justification: Closing with high confidence. Carla Walsh had 7 failed logins followed by a successful login from 10.50.1.31, which is her assigned workstation, during normal business hours. Retail Operations also completed a quarterly password rotation the previous day, making a forgotten or recently changed password the most likely explanation. MFA was approved on the first prompt, with no additional suspicious behavior. Failed Login Runbook closure criteria 1 and 2 apply.

```
MTB-A02  FAILED LOGIN THRESHOLD      Tue 23:18 EDT      Severity: Medium
Accounts  : 312 distinct accounts
Source    : 45.134.26.91 (external, geolocated to Netherlands)
Detail    : 1,284 authentication failures in an 11 minute window against the
           external webmail portal. Between 3 and 5 attempts per account.
           No successful authentications recorded.
MFA       : Not reached.
```

Field	Triage Log Entry
Alert ID	MTB-A02

Type	Failed Login
Decision	ESCALATE
Confidence	High
Runbook Step	Failed Login Runbook - escalation criteria 1 and 3
Linked Alerts	None identified

Justification: Escalating with high confidence. A single external source, 45.134.26.91, generated 1,284 failed login attempts across 312 different accounts in only 11 minutes. The low number of attempts per account combined with the large number of targeted accounts is consistent with a password-spraying attack designed to stay below lockout thresholds. The source is external and unrecognized, and although no successful authentications were recorded during the alert window, that does not prove no account was later compromised. Failed Login Runbook escalation criteria for multiple accounts from one source and an external source apply.

MTB-A03 FAILED LOGIN THRESHOLD Wed 02:00 EDT Severity: Low
 Account : svc-backup-agent
 Source : 10.50.2.25
 Detail : 4 authentication failures at 02:00:03. No success. This alert has
 fired at the same time every night for the past 14 nights.
 MFA : Not applicable, service account.

Field	Triage Log Entry
Alert ID	MTB-A03
Type	Failed Login
Decision	CLOSE
Confidence	High
Runbook Step	Failed Login Runbook - closure criterion 3
Linked Alerts	None identified

Justification: Closing with high confidence. The svc-backup-agent service account generated 4 failed authentications from 10.50.2.25 at 02:00, which matches its expected source and normal scheduled authentication time. The same alert has occurred every night for the past 14 nights, and the change record shows the backup agent credential was rotated but the application team has not yet updated the job. This issue is already documented under open ticket CHG-8802. Failed Login Runbook closure criterion 3 applies.

MTB-A04 FAILED LOGIN THRESHOLD Tue 23:47 EDT Severity: Medium
 Account : dkoenig
 Source : 10.50.1.77
 Detail : 9 authentication failures 23:47:19 to 23:51:02, followed by a
 successful authentication at 23:51:40. Account holds domain
 administrator privilege.
 MFA : Satisfied on the fourth push prompt.

Field	Triage Log Entry
Alert ID	MTB-A04
Type	Failed Login
Decision	ESCALATE
Confidence	High
Runbook Step	Failed Login Runbook - escalation criteria 2 and 4
Linked Alerts	None identified

Justification: Escalating with high confidence. Daniel Koenig's domain administrator account had 9 failed login attempts followed by a successful authentication from 10.50.1.77, which is not his assigned workstation. The activity occurred at 23:47, well outside normal business hours, and the staff directory shows that Koenig is on approved leave for the entire week. The account is privileged and the authentication succeeded after multiple MFA prompts, which makes the activity especially suspicious. Failed Login Runbook escalation criteria 2 and 4 apply.

MTB-A05 FAILED LOGIN THRESHOLD Wed 07:15 EDT Severity: Low
 Account : mnguyen
 Source : 198.51.100.22
 Detail : 3 authentication failures 07:15:44 to 07:16:20, followed by a
 successful authentication at 07:16:58 from a newly registered
 mobile device.
 MFA : Satisfied, approved push, first prompt.

Field	Triage Log Entry
Alert ID	MTB-A05
Type	Failed Login
Decision	CLOSE
Confidence	High
Runbook Step	Failed Login Runbook - closure criteria 1 and 2
Linked Alerts	None identified

Justification: Closing with high confidence. Minh Nguyen had 3 failed authentication attempts followed by a successful login from 198.51.100.22, which falls within Meridian Trust's corporate VPN egress range. The login occurred at 07:15, within normal business hours, and the staff directory notes that Nguyen received a replacement phone that was enrolled in MDM on Monday. The successful login came from a newly registered mobile device and MFA was approved on the first prompt, which is consistent with the recent device change. Failed Login Runbook closure criteria 1 and 2 apply.

6.2 Impossible travel alerts

MTB-B01 IMPOSSIBLE TRAVEL Wed 04:01 EDT Severity: High
 Account : rpatel
 Login 1 : Tue 03:14 EDT, 10.50.1.60, Pittsburgh US
 Login 2 : Wed 04:01 EDT, 102.89.44.7, Lagos NG
 Elapsed : 47 minutes
 Post-login: No sensitive system access recorded in the following hour.
 MFA : Satisfied on the sixth push prompt.

Field	Triage Log Entry
Alert ID	MTB-B01
Type	Impossible Travel
Decision	ESCALATE
Confidence	High
Runbook Step	Impossible Travel Runbook - escalation criteria 1 and 2
Linked Alerts	None identified

Justification: Escalating with high confidence. Rhea Patel authenticated from Pittsburgh and then from Lagos, Nigeria, with the lab providing an elapsed time of 47 minutes. Pittsburgh to Lagos is 5,578 miles, so the required travel speed would be approximately 7,123 mph, which is far above the roughly 600 mph threshold considered physically possible. The Lagos address is not part of Meridian Trust's corporate VPN range, and there is no approved travel on record for Patel. MFA was also only satisfied on the sixth push prompt, which adds further concern. Impossible Travel Runbook escalation criteria 1 and 2 apply.

MTB-B02 IMPOSSIBLE TRAVEL Tue 10:20 EDT Severity: Medium
 Account : jhaddad
 Login 1 : Tue 06:20 EDT, 10.50.1.63, Pittsburgh US
 Login 2 : Tue 10:20 EDT, 72.44.19.203, Miami US
 Elapsed : 4 hours 0 minutes
 Post-login: Opened the commercial lending pipeline report. Normal for this user.
 MFA : Satisfied, approved push, first prompt.

Field	Triage Log Entry
Alert ID	MTB-B02
Type	Impossible Travel
Decision	CLOSE
Confidence	High
Runbook Step	Impossible Travel Runbook - closure criterion 1
Linked Alerts	None identified

Justification: Closing with high confidence. Joseph Haddad authenticated from Pittsburgh at 06:20 and then from Miami at 10:20, giving 4 hours of elapsed time. Pittsburgh to Miami is 1,014 miles, which would require an average travel speed of about 254 mph, making the trip achievable by commercial air travel. The staff directory also confirms that Haddad has approved travel to a Miami conference from Tuesday through Friday. His post-login activity was normal for his role, and MFA was approved on the first prompt. Impossible Travel Runbook closure criterion 1 applies.

```
MTB-B03    IMPOSSIBLE TRAVEL           Wed 09:23 EDT    Severity: Medium
Account    : lbrennan
Login 1    : Wed 09:02 EDT, 10.50.1.71, Pittsburgh US
Login 2    : Wed 09:23 EDT, 198.51.100.41, Columbus US
Elapsed    : 21 minutes
Post-login: Routine access to data services tooling.
MFA        : Satisfied, approved push, first prompt.
```

Field	Triage Log Entry
Alert ID	MTB-B03
Type	Impossible Travel
Decision	CLOSE
Confidence	High
Runbook Step	Impossible Travel Runbook - closure criterion 2
Linked Alerts	None identified

Justification: Closing with high confidence. Liam Brennan authenticated from Pittsburgh and then 21 minutes later from 198.51.100.41, which is inside Meridian Trust's corporate VPN egress range 198.51.100.0/24. The Columbus location is therefore caused by where the bank's VPN traffic exits, not by Brennan physically traveling to Ohio. The staff directory also identifies Brennan as a remote worker who uses the corporate VPN daily, and his post-login activity was routine with MFA approved on the first prompt. Impossible Travel Runbook closure criterion 2 applies.

```
MTB-B04    IMPOSSIBLE TRAVEL           Tue 22:58 EDT    Severity: High
Account    : tokafor
Login 1    : Tue 21:50 EDT, 10.50.1.58, Pittsburgh US
Login 2    : Tue 22:58 EDT, 89.36.216.140, Bucharest RO
Elapsed    : 1 hour 8 minutes
Post-login: Accessed the wire transfer initiation system at 23:04.
MFA        : Satisfied on the ninth push prompt.
```

Field	Triage Log Entry
Alert ID	MTB-B04
Type	Impossible Travel

Decision	ESCALATE
Confidence	High
Runbook Step	Impossible Travel Runbook - escalation criteria 1, 2, and 3
Linked Alerts	MTB-C01, MTB-C02, MTB-D01

Justification: Escalating with high confidence. Thomas Okafor authenticated from Pittsburgh and then from Bucharest, Romania, only 1 hour and 8 minutes later. Pittsburgh to Bucharest is 4,998 miles, which would require a travel speed of approximately 4,410 mph, far above the roughly 600 mph threshold considered physically possible. There is no approved travel listed for Okafor, and the Bucharest address is not part of Meridian Trust's corporate VPN range. The account then accessed the wire transfer initiation system only six minutes after the Bucharest login, and MFA was not approved until the ninth push prompt. Impossible Travel Runbook escalation criteria 1, 2, and 3 apply.

```

MTB-B05    IMPOSSIBLE TRAVEL           Wed 09:15 EDT    Severity: Medium
Account    : sgrigsby
Login 1    : Wed 07:40 EDT, 10.50.1.66, Pittsburgh US
Login 2    : Wed 09:15 EDT, 99.240.18.66, Toronto CA
Elapsed    : 1 hour 35 minutes
Post-login: Accessed the internal audit workpaper repository.
MFA        : Satisfied, approved push, first prompt.
Note       : No travel request on file. Audit staff travel is booked departmentally
              and is not always recorded centrally.

```

Field	Triage Log Entry
Alert ID	MTB-B05
Type	Impossible Travel
Decision	ESCALATE
Confidence	Medium
Runbook Step	Impossible Travel Runbook - travel record requires validation before closure
Linked Alerts	None identified

Justification: Escalating with medium confidence. Sara Grigsby authenticated from Pittsburgh and then from Toronto 1 hour and 35 minutes later. Pittsburgh to Toronto is 224 miles, which would require an average speed of about 141 mph. That is too fast for normal ground travel but could be consistent with air travel. However, there is no travel request on file, although the staff note says Audit travel is booked departmentally and is not always recorded centrally. MFA was approved on the first prompt and the post-login activity involved the internal audit workpaper repository, which is consistent with her role. Because legitimate travel is plausible but cannot be confirmed from the available records, Tier 2 should verify the travel with the Audit department before the alert is closed.

6.3 Business email compromise indicator alerts

```
MTB-C01 MAILBOX RULE CREATED Tue 23:09 EDT Severity: High
Mailbox : tokafor
Created by: tokafor, from 89.36.216.140
Rule name : ..
Rule logic: IF subject or body contains any of: wire, invoice, payment,
            beneficiary, confirm, approval
            THEN move to folder 'RSS Subscriptions' AND mark as read
```

Field	Triage Log Entry
Alert ID	MTB-C01
Type	Business Email Compromise Indicator
Decision	ESCALATE
Confidence	High
Runbook Step	BEC Runbook - escalation criterion 1
Linked Alerts	MTB-B04, MTB-C02, MTB-D01

Justification: Escalating with high confidence. A mailbox rule was created for Thomas Okafor that searches for financial terms including wire, invoice, payment, beneficiary, confirm, and approval, then moves matching messages to the RSS Subscriptions folder and marks them as read. The rule was created from 89.36.216.140, the same Bucharest address involved in MTB-B04. This behavior is designed to hide payment-related communications and is specifically identified by the BEC Runbook as an escalation condition. The alert also links directly to the suspicious login and wire activity involving the same account.

```
MTB-C02 LOOKALIKE DOMAIN Tue 19:44 EDT Severity: High
From : t.okafor@meridian-trust.com
To : tokafor@meridiantrust.com
Subject : Treasury portal - action required before cut-off
Detail : Sender domain registered 9 days ago. SPF: fail. DKIM: none.
        DMARC: none. Message contained a link to a credential entry page
        styled as the Meridian Trust treasury portal.
Gateway : DELIVERED to inbox. Not quarantined.
```

Field	Triage Log Entry
Alert ID	MTB-C02
Type	Business Email Compromise Indicator
Decision	ESCALATE
Confidence	High
Runbook Step	BEC Runbook - escalation criteria 3 and 4

Linked Alerts	MTB-B04, MTB-C01, MTB-D01
----------------------	---------------------------

MTB-C03 EXTERNAL AUTO-REPLY Tue 07:02 EDT Severity: Low
 Mailbox : jhaddad
 Detail : Out-of-office auto-reply enabled for external senders. Text reads:
 'I am at a conference in Miami until Friday. For urgent lending
 matters contact Commercial Lending duty desk.'
 Created by: jhaddad, from 10.50.1.63, Mon 16:50 EDT

Field	Triage Log Entry
Alert ID	MTB-C03
Type	Business Email Compromise Indicator
Decision	CLOSE
Confidence	High
Runbook Step	BEC Runbook - closure criterion 1
Linked Alerts	MTB-B02

Closing with high confidence. Joseph Haddad enabled an out-of-office auto-reply for external senders while he was legitimately traveling to a conference in Miami. The rule was created from his assigned workstation during normal business hours, and the staff directory confirms his approved travel from Tuesday through Friday. The message simply directs urgent lending matters to the Commercial Lending duty desk and does not hide, delete, or forward messages. BEC Runbook closure criterion 1 applies.

MTB-C04 EXTERNAL FORWARDING RULE Tue 14:31 EDT Severity: Medium
 Mailbox : bfoster
 Created by: bfoster, from 10.50.1.80
 Rule name : 'Copy to personal'
 Rule logic: IF sender is in 'Marketing Vendors' contact group
 THEN forward a copy to b.foster.home@exampleemail.com
 Detail : Rule created during business hours from the user's own workstation.
 No attempt to hide the rule. User has not been contacted.

Field	Triage Log Entry
Alert ID	MTB-C04
Type	Business Email Compromise Indicator
Decision	ESCALATE
Confidence	Medium
Runbook Step	BEC Runbook - escalation criterion 2

Linked Alerts	None identified
----------------------	-----------------

Justification: Escalating with medium confidence. Brian Foster created a rule from his assigned workstation during business hours that forwards messages from the Marketing Vendors contact group to an external personal email address. The activity was not hidden and may have been created intentionally, but the BEC Runbook states that any rule forwarding mail outside the bank should be escalated. Tier 2 should confirm with Foster whether he knowingly created the rule and whether this forwarding is authorized. BEC Runbook escalation criterion 2 applies.

```
MTB-C05    DISPLAY NAME IMPERSONATION    Wed 06:12 EDT    Severity: Medium
From       : diane.kessler.cfo@examplemail.com
Display    : 'Diane Kessler'
To         : 1 recipient (Accounts Payable shared mailbox)
Subject    : Quick favour - are you at your desk?
Detail     : No links, no attachments. Generic text. Classic gift-card pretext.
Gateway    : QUARANTINED before delivery. Recipient never saw it.
            Reported independently by a second employee who received a
            similar message at a previous employer.
```

Field	Triage Log Entry
Alert ID	MTB-C05
Type	Business Email Compromise Indicator
Decision	ESCALATE
Confidence	Medium
Runbook Step	BEC Runbook - escalation criterion 4
Linked Alerts	None identified

Justification: Escalating with medium confidence. The message impersonated Diane Kessler, Meridian Trust's Chief Financial Officer, and was sent to the Accounts Payable shared mailbox using a common gift-card pretext. Although the gateway successfully quarantined the message before delivery and there were no links or attachments, the BEC Runbook specifically requires escalation when an executive is impersonated or targeted. The blocked delivery reduces the immediate risk, but the executive impersonation still warrants review. BEC Runbook escalation criterion 4 applies.

6.4 Suspicious wire transfer alerts

```
MTB-D01    NEW BENEFICIARY, HIGH VALUE    Tue 23:12 EDT    Severity: High
Initiated  : tokafor
Amount     : 47,500.00 USD
Beneficiary: Sorana Trading SRL
Bank       : Banca Transilvania, Romania
Detail     : Beneficiary added to the payee list at 23:06 the same evening.
            First payment to this beneficiary. Initiated 6 hours after the
            17:00 wire cut-off. Dual approval: NOT YET OBTAINED, queued.
```

Field	Triage Log Entry
Alert ID	MTB-D01
Type	Suspicious Wire Transfer
Decision	ESCALATE
Confidence	High
Runbook Step	Suspicious Wire Transfer Runbook - escalation criteria 1 and 4
Linked Alerts	MTB-B04, MTB-C01, MTB-C02

Justification: Escalating with high confidence. Thomas Okafor initiated a \$47,500 wire to Sorana Trading SRL, a newly added beneficiary with no previous payment history. The beneficiary was added only minutes before the transfer, and the wire was initiated about six hours after the 17:00 cut-off. The transfer is still awaiting dual approval, but Okafor's account is already linked to the suspicious Bucharest login, lookalike-domain phishing message, and mailbox rule alerts. Suspicious Wire Transfer Runbook escalation criteria 1 and 4 apply.

```
MTB-D02    RECURRING HIGH VALUE           Tue 09:30 EDT      Severity: Low
Initiated  : tokafor
Amount     : 129,880.00 USD
Beneficiary: ADP Payroll Services
Bank       : Wells Fargo, US
Detail     : Fortnightly payroll run. Amount within the normal range for this
              beneficiary. Dual approval obtained from Treasury lead.
```

Field	Triage Log Entry
Alert ID	MTB-D02
Type	Suspicious Wire Transfer
Decision	ESCALATE
Confidence	High
Runbook Step	Suspicious Wire Transfer Runbook - escalation criterion 4
Linked Alerts	MTB-B04, MTB-C01, MTB-C02, MTB-D01

Justification: Escalating with high confidence. The \$129,880 transfer to ADP Payroll Services matches the beneficiary's normal payment range, follows the usual fortnightly payroll pattern, and received the required dual approval. However, the initiating account tokafor is also involved in a suspicious Bucharest login, a malicious mailbox rule, a lookalike-domain phishing message, and a separate suspicious wire transfer. Because the initiating account is already associated with other alerts in the queue, the Suspicious Wire Transfer Runbook requires escalation even though this individual transaction appears legitimate. Tier 2 should confirm that the payroll payment was initiated before or independently of the account compromise.

MTB-D03 THRESHOLD PATTERN Tue 11:02 - 16:40 Severity: Medium
 Initiated : rharper (Accounts Payable)
 Detail : 5 outbound transfers in one day, all to different beneficiaries,
 none previously used:
 11:02 9,850.00 USD 13:15 9,700.00 USD
 14:28 9,900.00 USD 15:51 9,750.00 USD
 16:40 9,800.00 USD
 Total 49,000.00 USD. No single transfer reached the 25,000 USD
 dual-approval threshold, so none required a second approver.

Field	Triage Log Entry
Alert ID	MTB-D03
Type	Suspicious Wire Transfer
Decision	ESCALATE
Confidence	High
Runbook Step	Suspicious Wire Transfer Runbook - escalation criterion 3
Linked Alerts	MTB-D04

Justification: Escalating with high confidence. Ray Harper initiated five transfers in one day to five different beneficiaries that had never been used before. Each transfer was kept below the \$25,000 dual-approval threshold, with amounts ranging from \$9,700 to \$9,900, for a combined total of \$49,000. The pattern is consistent with structuring transfers to avoid secondary approval requirements. Suspicious Wire Transfer Runbook escalation criterion 3 applies, and MTB-D04 should also be linked because it involves the same Accounts Payable account.

MTB-D04 BENEFICIARY DETAILS CHANGED Mon 15:20 EDT Severity: High
 Beneficiary: Castlereagh Supply Co
 Changed by : rharper (Accounts Payable)
 Detail : Account number and receiving bank changed from PNC Bank US to
 an account at a different institution. Change requested by an
 email from the vendor's accounts contact. No callback to a
 previously known telephone number was recorded.
 Scheduled payment of 88,400.00 USD due Thursday.

Field	Triage Log Entry
Alert ID	MTB-D04
Type	Suspicious Wire Transfer
Decision	ESCALATE
Confidence	High
Runbook Step	Suspicious Wire Transfer Runbook - escalation criterion 2
Linked Alerts	MTB-D03

Justification: Escalating with high confidence. The bank account information for Castlereagh Supply Co was changed from its established PNC Bank account to an account at a different institution shortly before an \$88,400 scheduled payment. The change request came by email, and there is no record that Accounts Payable verified the request by calling a previously known telephone number. Because the beneficiary's banking details changed shortly before payment and the request was not independently verified, Suspicious Wire Transfer Runbook escalation criterion 2 applies. MTB-D03 is also linked because both alerts involve Ray Harper's Accounts Payable account.

MTB-D05 HIGH VALUE Tue 14:05 EDT Severity: Low
 Initiated : tokafor
 Amount : 250,000.00 USD
 Beneficiary: Harrow Logistics Ltd
 Bank : Barclays, UK
 Detail : Established beneficiary. Amount at the top of its normal range but within it. Approval reference CR-2291 recorded. Dual approval obtained from the CFO and the Treasury lead.

Field	Triage Log Entry
Alert ID	MTB-D05
Type	Suspicious Wire Transfer
Decision	ESCALATE
Confidence	High
Runbook Step	Suspicious Wire Transfer Runbook - escalation criterion 4
Linked Alerts	MTB-B04, MTB-C01, MTB-C02, MTB-D01, MTB-D02

Justification: Escalating with high confidence. The \$250,000 transfer to Harrow Logistics Ltd is within the beneficiary's normal range, has approval reference CR-2291, and received the required dual approval from the CFO and Treasury lead. However, the initiating account tokafor is already linked to a suspicious Bucharest login, a malicious mailbox rule, a lookalike-domain phishing message, and another suspicious wire transfer. Because the initiating account is associated with other alerts in the queue, the Suspicious Wire Transfer Runbook requires escalation even though this transaction appears legitimate on its own. Tier 2 should confirm that this payment was authorized and initiated before the account compromise.

6.5 Step by step

1. Read Sections 4 and 5 before you touch the queue. Most wrong answers on this lab come from skipping the reference data.
2. Work each alert. Identify the type, apply the runbook, decide CLOSE or ESCALATE, and record your justification and confidence.
3. Do the arithmetic on every impossible-travel alert yourself. Do not take the alert's word for it, and do not take the word 'impossible' in the alert title as a finding.
4. Check every address in the queue against Section 4.3 before you treat it as external.

5. Fill in the Linked alerts column as you go. When you have finished all twenty, sort your log by account name and look again.

Account	Related Alerts
jhaddad	MTB-B02, MTB-C03
tokafor	MTB-B04, MTB-C01, MTB-C02, MTB-D01, MTB-D02, MTB-D05
rharper	MTB-D03, MTB-D04

6. Count your escalations. If you escalated more than about half the queue, re-read the ones you are least sure about. If you escalated fewer than five, do the same.

CLOSE: 6

ESCALATE: 14

7. Identify the two alerts you found genuinely ambiguous, and write a paragraph on each explaining what would settle it and who you would ask.

Ambiguous Alert 1 - MTB-B05:

MTB-B05 was difficult because Sara Grigsby's travel from Pittsburgh to Toronto could be legitimate, but the available records do not confirm it. The required speed is approximately 141 mph, which is too fast for normal driving but possible if she flew. There is no central travel request on file, but the staff notes explain that Audit travel is booked departmentally and is not always recorded centrally. I would ask the Audit department or Grigsby's manager to confirm whether she was scheduled to travel to Toronto. If they confirm the trip, I would close the alert; if they cannot, I would continue the escalation.

Ambiguous Alert 2 - MTB-C05:

MTB-C05 was ambiguous because there are valid reasons both to close and escalate it. The message was generic, contained no links or attachments, and was quarantined before the recipient ever saw it, which matches one of the BEC Runbook's closure conditions. However, the sender impersonated Meridian Trust's CFO and targeted Accounts Payable, while the runbook also says executive impersonation should be escalated. I chose to escalate because executive impersonation creates a higher potential financial risk. I would ask Tier 2 to determine whether similar messages targeted other employees or whether there is evidence of a broader campaign before deciding whether further investigation is necessary.

One account appears in more than one category

Sort your triage log by account name before you call the queue finished. That single step is the difference between twenty individual alerts and one incident.

If you find it, say so explicitly in your escalation note. That note is what Day 2 starts from.

7. Day 1: Writing Escalation Notes

Everything you escalate needs a note. The note is the entire handover. Tier 2 will act on what you wrote, not on what you meant, and on a busy shift they will not come and ask you.

7.1 The format

Field	What goes in it
Alert ID and type	Which alert, and what kind
What was observed	The facts only. Accounts, addresses, times, amounts. No interpretation yet.
Why it is suspicious	Your reasoning, and the runbook criterion you applied
What Tier 2 should look at first	The single most useful next step. Be specific.
Related alerts	Any other alert ID you think belongs with this one
Urgency	Your assessment, and why. Money in motion beats everything else.

7.2 A worked escalation note

```

ALERT      : MTB-A02, failed login threshold
OBSERVED   : 1,284 authentication failures against the external webmail portal
              between 23:18 and 23:29 Tuesday, from 45.134.26.91, spread across
              312 distinct accounts at 3 to 5 attempts each. No successes.
SUSPICIOUS : The low per-account attempt count combined with the very high
              account count is the signature of password spraying rather than
              brute force. The attempt count per account sits deliberately below
              our lockout threshold. Failed Login Runbook escalation criterion 1.
FIRST STEP : Confirm whether any of the 312 accounts authenticated successfully
              from any source in the following 24 hours. The absence of success
              during the spray does not mean the attacker learned nothing.
RELATED    : None identified.
URGENCY    : Medium. No confirmed compromise, but the source is still active
              and the account list suggests prior enumeration of our directory.
  
```

What makes that note useful

It separates what was seen from what it means, so Tier 2 can disagree with the interpretation without having to re-derive the facts.

The first step is a specific question with a yes or no answer, not 'investigate further'.

It names the runbook criterion, so the decision can be reviewed against procedure months later.

It says what the absence of evidence does not prove. That sentence is what separates a Tier 1 analyst from a ticket forwarder.

7.3 Step by step

1. Write a note in the Section 7.1 format for every alert you escalated.

Alert ID and Type	What Was Observed	Why Suspicious	Tier 2 First Step	Related Alerts	Urgency
MTB-A02 - Failed Login	1,284 failures from 45.134.26.91 against 312 accounts in 11 minutes. No successes.	Low attempts per account across many accounts indicates password spraying from an external source.	Check whether any targeted accounts successfully authenticated in the next 24 hours.	None	Medium - Coordinated attack, but no confirmed compromise.
MTB-A04 - Failed Login	Domain admin dkoenig had 9 failures then a success from 10.50.1.77 at 23:51. MFA approved on fourth push.	Privileged account, wrong workstation, after hours, and Koenig is on leave.	Review what the account did immediately after login.	None	High - Possible domain admin compromise.
MTB-B01 - Impossible Travel	rpattel logged in from Pittsburgh and Lagos with an intended 47-minute gap. MFA approved on sixth push.	5,578 miles in 47 minutes requires about 7,123 mph and cannot be legitimate travel.	Review the Lagos session and device activity.	None	High - Likely unauthorized authentication.
MTB-B04 - Impossible Travel	tokafor logged in from Pittsburgh and Bucharest 68 minutes apart, then accessed the wire system. MFA approved on ninth push.	Required speed is about 4,410 mph and sensitive financial access followed immediately.	Review all Bucharest session activity, especially wire-system actions.	C01, C02, D01, D02, D05	Critical - Likely compromised wire initiator account.
MTB-B05 - Impossible Travel	sgrigsby logged in from Pittsburgh and Toronto 95 minutes apart and accessed audit records.	About 141 mph is too fast for driving but possible by air. Travel is not confirmed centrally.	Confirm Toronto travel with the Audit department.	None	Medium - Could be legitimate, but needs verification.
MTB-C01 - Mailbox Rule	Rule . . hid messages containing financial terms and marked them read. Created from the Bucharest IP.	Hiding payment-related messages is a strong BEC indicator.	Identify which messages were hidden and whether they affected payment review.	B04, C02, D01, D02, D05	Critical - Could hide warnings about fraudulent payments.
MTB-C02 - Lookalike Domain	Lookalike meridian-trust.com sent Okafor a fake treasury login page. SPF failed, no DKIM	Credential phishing targeted an authorized wire initiator.	Determine whether Okafor clicked the link or entered credentials.	B04, C01, D01, D02, D05	High - Likely initial access attempt.

	or DMARC.				
MTB-C04 - External Forwarding	Brian Foster created a rule forwarding Marketing Vendor messages to a personal email account.	External forwarding creates a data-loss path and requires escalation under the BEC runbook.	Confirm with Foster whether the rule was authorized.	None	Medium - Possibly legitimate, but policy and intent need verification.
MTB-C05 - Impersonation	An external sender impersonated CFO Diane Kessler in a gift-card message to Accounts Payable. Gateway quarantined it.	Executive impersonation requires escalation even though delivery was blocked.	Check whether similar messages reached other employees.	None	Medium - Immediate message blocked, but campaign may be broader.
MTB-D01 - New Beneficiary	Okafor initiated a \$47,500 wire to newly added Sorana Trading after cut-off. Dual approval not yet obtained.	New beneficiary, significant first payment, after-hours activity, and linked compromised account.	Can the \$47,500 transfer still be stopped before approval?	B04, C01, C02, D02, D05	Critical - Money is still in motion.
MTB-D02 - Payroll Wire	\$129,880 ADP payment matched normal payroll activity and had dual approval.	Transaction looks normal, but tokafor appears in multiple suspicious alerts.	Confirm the payment was legitimately initiated before the compromise.	B04, C01, C02, D01, D05	Medium - Likely legitimate, but account compromise requires review.
MTB-D03 - Threshold Pattern	Five new-beneficiary transfers totaled \$49,000, each below the \$25,000 approval threshold.	Pattern suggests deliberate structuring to avoid dual approval.	Verify the beneficiaries and supporting business documentation.	D04	High - \$49,000 moved without secondary approval.
MTB-D04 - Beneficiary Change	Castlereagh bank details changed by email without callback verification. \$88,400 payment is due Thursday.	Payment details changed shortly before a large scheduled payment with no out-of-band verification.	Call the vendor using a previously verified number.	D03	Critical - \$88,400 is at risk.
MTB-D05 - High Value Wire	\$250,000 Harrow Logistics payment was within normal range and fully	Payment looks legitimate, but tokafor is	Confirm the payment was authorized and initiated before	B04, C01, C02, D01, D02	Medium - Strong legitimacy indicators, but

	approved.	involved in multiple suspicious alerts.	the compromise.		compromised account requires review.
--	-----------	---	-----------------	--	--------------------------------------

- For your highest-urgency escalation, write the first step as a question that can be answered yes or no.

Can the \$47,500 transfer still be stopped before approval?

- For every alert you closed, write one or two sentences of justification in your triage log. A closure with no reasoning is itself a finding your shift lead will raise.

Step 3 - Closure Justifications: All alerts marked CLOSE include a written justification in the triage log explaining the evidence and runbook criteria used to support the decision.

- Pick the three closures you are least confident about and add a sentence to each saying what would change your mind.

MTB-B02 - Impossible Travel

I would change my decision if Joseph Haddad's travel itinerary did not support him being in Miami by 10:20, or if the Miami login came from an unfamiliar device or showed unusual activity.

MTB-A05 - Failed Login

I would change my decision if the newly registered mobile device could not be confirmed as Minh Nguyen's replacement phone or if additional suspicious authentication activity appeared from his account.

MTB-A01 - Failed Login

I would change my decision if Carla Walsh denied making the login attempts, if the source workstation showed signs of compromise, or if similar failed-login activity continued after the password rotation.

8. Day 2: Incident Kickoff

Overnight, Tier 2 worked the escalations your cohort raised. One of them was confirmed as a live incident and has been handed back to your team to run as a full response.

```
From    : Tier 2 Investigation
To      : Incident Response Team
Time    : Thursday 07:05 EDT
Subject : MTB-IR-2026-0917 - confirmed BEC, wire in queue, ACT NOW
```

Your Tier 1 escalations on tokafor are confirmed. This is a live business email compromise with money still in motion.

The 47,500 USD wire to Sorana Trading SRL is sitting in the dual-approval queue. It has NOT been approved and it has NOT sent. If a second approver clears it this morning it goes, and recovering a wire to a Romanian account after the fact is close to impossible.

You have the response. Full roles. I want containment before the Treasury morning approval run at 09:00.

8.1 Assign your roles

Role	Owns	First action
Incident Commander	Coordination, decisions, status communication, the timeline. Does not investigate personally.	Set the response plan and a check-in cadence. Confirm who is doing what.
Forensic Analyst	Establishing what actually happened, how far it goes, and what is still at risk.	Reconstruct the attack chain from the Day 1 alerts and the Section 9 evidence.
Remediation Specialist	Containment actions and the action log. Every action timestamped.	Identify what can be stopped right now, and in what order.

Teams of two

Teams 1, 2 and 3 are pairs. One person holds two roles. The usual split is Incident Commander plus Remediation Specialist on one person, Forensic Analyst on the other.

Team 4 has three people and fills all three roles separately.

Whichever way you split it, every member must be able to explain any part of the response during review, not just their own role.

Role	First Action
Incident Commander	Set the response plan, establish priorities, and track decisions and timing.
Forensic Analyst	Reconstruct the attack chain using the Day 1 alerts and Section 9 evidence.
Remediation Specialist	Identify the containment actions that can stop the financial loss immediately and record them in order.

This lab was completed individually, so all three incident response roles were performed by a single analyst. The responsibilities were kept separate so that coordination, investigation, and containment decisions remained clearly documented.

8.2 The clock

It is 07:05. The Treasury approval run is at 09:00. Anything not contained by then is exposed. Record the real time you take each action, not the scenario time, and note the scenario time you are working against.

The response begins at 07:05, with the Treasury approval run scheduled for 09:00. The immediate priority is to prevent the pending \$47,500 Sorana Trading wire from being approved or released before that deadline. Containment and investigation should happen in parallel, with low-risk and reversible containment actions taken first while the incident is still being analyzed. All response actions should be documented with both the real time they were taken and the scenario time being worked against.

Containment first, investigation second, and do both at once

The natural instinct is to investigate fully before acting. With money in a queue that instinct is wrong.

There are actions you can take in the first ten minutes that cost nothing if you turn out to be wrong and save 47,500 US dollars if you are right. Take those first.

The Incident Commander's first real decision is which actions are reversible enough to take before the picture is complete.

9. Day 2: The Evidence Package

Tier 2 pulled the following. Combine it with the Day 1 alerts on tokafor: MTB-C02, MTB-B04, MTB-C01 and MTB-D01.

9.1 The phishing message, in full

```
Received: from mail.meridian-trust.com (193.42.55.18)
  by mx01.meridiantrust.com; Tue, 19:44:02 -0400
Authentication-Results: mx01.meridiantrust.com;
  spf=fail (sender IP is 193.42.55.18) smtp.mailfrom=meridian-trust.com;
  dkim=none; dmarc=none
From: "Meridian Trust IT Service Desk" <t.okafor@meridian-trust.com>
To: tokafor@meridiantrust.com
Subject: Treasury portal - action required before cut-off

Thomas,

Our records show your treasury portal certificate expires tonight at 23:59.
If it is not renewed before then your wire initiation rights will be suspended
and tomorrow's payroll run will fail.

Renew here: https://treasury-meridiantrust\[.\]com/portal/renew

This takes under a minute. Please do not reply to this message; the service
desk mailbox is not monitored overnight.

Meridian Trust IT Service Desk
```

9.2 Identity and access log, tokafor

```
Tue 19:44:02 Message MTB-C02 delivered to inbox
Tue 19:52:18 Outbound HTTPS to treasury-meridiantrust.com from 10.50.1.58
Tue 21:50:04 Authentication SUCCESS 10.50.1.58 Pittsburgh US MFA 1st push
Tue 22:11:37 Authentication FAILURE 89.36.216.140 Bucharest RO MFA denied
Tue 22:13:09 Authentication FAILURE 89.36.216.140 Bucharest RO MFA denied
Tue 22:15:44 Authentication FAILURE 89.36.216.140 Bucharest RO MFA timeout
Tue 22:22:51 Authentication FAILURE 89.36.216.140 Bucharest RO MFA timeout
Tue 22:31:06 Authentication FAILURE 89.36.216.140 Bucharest RO MFA denied
Tue 22:40:19 Authentication FAILURE 89.36.216.140 Bucharest RO MFA timeout
Tue 22:47:55 Authentication FAILURE 89.36.216.140 Bucharest RO MFA timeout
Tue 22:53:12 Authentication FAILURE 89.36.216.140 Bucharest RO MFA timeout
Tue 22:58:41 Authentication SUCCESS 89.36.216.140 Bucharest RO MFA 9th push
Tue 23:04:27 Wire initiation system accessed 89.36.216.140
Tue 23:06:55 Payee added: Sorana Trading SRL 89.36.216.140
Tue 23:09:13 Mailbox rule '..' created 89.36.216.140
Tue 23:12:40 Wire initiated, 47,500.00 USD 89.36.216.140
Tue 23:14:02 Session ended
```

Wed 00:00 No further activity on this account through Thursday 07:00

Look at the multi-factor sequence

Eight denials and timeouts across 47 minutes, then an approval on the ninth prompt at 22:58.

That is not an attacker defeating multi-factor authentication. It is a tired person at eleven at night approving a prompt to make it stop.

This pattern has a name and it is a specific technique your Forensic Analyst should identify and your after-action report should address. The control worked eight times. It was the ninth that mattered.

9.3 Mailbox state, tokafor

```
Rule name      : '..' (two period characters, no other text)
Created       : Tue 23:09:13 from 89.36.216.140
Condition     : subject or body contains any of
                wire / invoice / payment / beneficiary / confirm / approval
Action        : move to folder 'RSS Subscriptions', mark as read
Messages moved : 4 since creation
```

Messages currently in 'RSS Subscriptions':

```
Wed 07:31 Treasury Ops 'Re: new payee Sorana Trading - can you confirm?'
Wed 08:02 Treasury lead 'Second approval needed - 47,500 Sorana Trading'
Wed 14:55 Accounts Payable 'Payment run query - beneficiary confirm'
Thu 06:40 Treasury lead 'Chasing - Sorana approval still outstanding'
```

This is what the rule was for

Two colleagues have already queried the payment. Thomas Okafor has not seen either message, and neither has anyone else.

A mailbox rule that hides the replies is what turns a single fraudulent wire into one that gets approved. The attacker did not need to stop anyone noticing. They needed to stop the person who would notice from being asked.

9.4 Wire transfer system state

```
Transfer ID    : WT-2026-091703
Amount        : 47,500.00 USD
Beneficiary    : Sorana Trading SRL, Banca Transilvania, Romania
Payee added    : Tue 23:06:55 by tokafor
Initiated     : Tue 23:12:40 by tokafor
Status        : PENDING SECOND APPROVAL
Queue position : Included in the Thursday 09:00 Treasury approval run
Approvers     : Treasury lead, Deputy Treasurer, CFO (any one may approve)
```

Other payees added by tokafor in the last 30 days: none

Other transfers initiated by tokafor in the last 30 days: 11, all to established beneficiaries, all inside business hours, all dual-approved.

9.5 Step by step for the Forensic Analyst

1. Build the attack chain in order, from the first event to the last, using the Day 1 alerts and everything in Section 9. Name the mechanism at each step.
2. Identify the initial access vector and state precisely what the attacker obtained from it.
3. Explain how the attacker got past multi-factor authentication. Name the technique.
4. Establish the scope. Which accounts, which systems, which mailboxes, and what data was exposed. Say clearly what you checked to conclude the scope stops there.
5. Establish what almost happened but has not happened yet. This is the sentence the Incident Commander will brief upward.
6. Establish what is still at risk if you do nothing for the next hour.
7. Note anything you cannot determine from the evidence you have, and what you would need.

9.6 Record: confirmed scope

Question	Your finding	Evidence
What happened		
How did they get in		
How did they get past MFA		
What almost happened		
What is still at risk		
What we cannot yet determine		

10. Day 2: Containment and Remediation

The Remediation Specialist owns this section. Every action gets a timestamp, in order, whether or not it worked.

10.1 Decide your order

Below are nine candidate actions in no particular order. Not all of them are appropriate, and one of them would actively damage the response. Put the ones you would take in the order you would take them, and say why you rejected the rest.

#	Candidate action
1	Disable the tokafor account
2	Cancel or place a stop on transfer WT-2026-091703
3	Delete the mailbox rule '..'
4	Notify the Treasury approvers not to approve the Sorana Trading payment
5	Force a password reset and revoke all active sessions for tokafor
6	Remove Sorana Trading SRL from the payee list

#	Candidate action
7	Wipe and rebuild Thomas Okafor's workstation
8	Block the lookalike domain meridian-trust.com at the mail gateway
9	Telephone Thomas Okafor on a known number and tell him what has happened

Three things to think about before you order that list

Which single action stops the money? It is not the one most teams reach for first, and it is not the one that feels most decisive.

Which action destroys evidence you have not collected yet? Do that one late, or collect first.

Which action is on the list to see whether you will take it without justification? A response that damages the bank more than the attacker did is still a failed response.

10.2 Record: containment action log

Order	Time	Action taken	Who	Why now	Confirmed effective by
1					
2					
3					
4					
5					
6					

10.3 Confirm containment actually worked

Containment is not a list of things you did. It is a set of claims you can prove. For each claim below, state how you verified it.

Claim	How you verified it
The compromised account can no longer authenticate or act	
The 47,500 USD transfer cannot be approved or released	
The mailbox rule is gone and the hidden messages are back where they belong	
The attacker cannot simply repeat the same attack tomorrow	
Nothing else the attacker set up is still in place	

The fourth claim is the one teams forget

Resetting a password stops this session. It does nothing about the lookalike domain, which is still registered, still resolves, and can send another message this afternoon.

Ask what the attacker still has after your containment. If the answer includes anything reusable, your containment is not finished.

10.4 The improvement

Identify one process or technical improvement that would have caught or prevented this earlier. Be specific enough that someone could implement it.

- **Weak** - 'better security awareness training'.
- **Strong** - a named control, at a named point in the chain, with what it would have caught and roughly when.

There are at least five defensible answers in this incident. Pick the one you would actually argue for in a meeting, and say what it would cost or inconvenience.

11. Day 2: Team After-Action Report

Come back together as a full team and produce one report covering the whole incident, from the original Tier 1 alerts through to containment.

11.1 The incident timeline

One merged timeline. Build it from the Day 1 alerts, the Section 9 evidence and your own action log.

Time	Event	Source	Who knew at the time
Tue 19:44			
Tue 19:52			
Tue 21:50			
Tue 22:11			
Tue 22:58			
Tue 23:04			
Tue 23:06			
Tue 23:09			
Tue 23:12			
Wed 07:31			
Wed AM			
Thu 07:05			

Time	Event	Source	Who knew at the time
Thu ...			

The fourth column is the interesting one. For each event, note who at the bank knew about it at the time it happened. The gaps in that column are the finding.

11.2 Role performance and hand-offs

1. Each role writes two or three sentences on what they did and what they decided.
2. Identify the hand-off that worked least well. Every team has one. Say what information failed to move, and when.
3. State what you would change about how the team communicated, specifically enough to do differently next time.

11.3 The Tier 1 question

Your cohort raised four separate alerts on this account on Day 1: a lookalike domain, an impossible-travel login, a mailbox rule, and a wire transfer. They arrived in three different categories over 28 hours.

1. Did anyone link them at Tier 1? Check your own Day 1 triage log honestly and say so either way.
2. If they had been linked on Tuesday night, what would have been different?
3. What would make an analyst more likely to link them next time? Consider both what the analyst does and what the tooling does.

Be honest in 11.3

Most analysts do not link them, because the alerts arrive separately, in different queues, hours apart, and each has a plausible individual explanation.

A report that claims the team spotted it immediately teaches nobody anything. A report that says nobody linked them and works out why is the one worth writing.

11.4 Report structure to follow

Section	Contents
Executive summary	Three to five sentences for a non-technical reader. What happened, what was at risk, what was stopped.
Incident timeline	Your merged timeline from Section 11.1, including who knew what and when.
Attack chain	Initial access through to the wire, mechanism by mechanism.
Scope	What was affected, and what you checked to conclude it stops there.
Containment and remediation	Your action log, in order, with verification for every claim.
Role summary and hand-offs	Who held which role, and the hand-off analysis from Section 11.2.

Section	Contents
Tier 1 correlation review	Your honest answers to Section 11.3.
Recommended improvement	Your improvement from Section 10.4, with its cost or inconvenience.

12. Deliverables

Submit the following through the class shared drive.

12.1 Day 1, individual

- Your triage log covering all twenty alerts, with a decision, a confidence level and a justification for every one.
- An escalation note in the Section 7.1 format for every alert you escalated.
- A short closure justification for every alert you closed.
- Your written analysis of the two alerts you found genuinely ambiguous, and what would settle each.
- Your Linked alerts column, completed.

12.2 Day 2, team

- Your confirmed scope table from Section 9.6.
- Your containment action log from Section 10.2, timestamped and in order, with your reasoning for the actions you rejected.
- Your containment verification from Section 10.3.
- Your combined after-action report with all eight sections from Section 11.4, including who held which role.

13. Reflection Questions

Answer briefly in your own words, three to five sentences each. Graded on reasoning, not length.

13.1 Day 1

1. What made one of your alerts clearly escalation-worthy versus one you closed? Name the specific detail that tipped it, not the general category.
2. Two alerts in the queue looked alarming and were benign, and at least one looked routine and was not. What does that tell you about triaging on severity labels?
3. Why does a Tier 1 escalation note matter so much to how quickly Tier 2 can act? Answer from the point of view of the person receiving it at three in the morning.
4. You were asked to record a justification for closures as well as escalations. Why does a bank care about the reasoning behind an alert nobody acted on?

13.2 Day 2

1. The multi-factor control worked eight times and failed on the ninth. Is that a failure of the control, of the user, or of the design? Argue your position.

2. What was the hardest hand-off between roles during your response, and what would you change about how your team communicated?
3. The attacker's mailbox rule hid four messages from two colleagues who had already spotted the problem. What does that tell you about controls that depend on somebody noticing something?
4. Your team had to act before the investigation was complete. How did you decide which actions were safe to take early, and would you make the same calls again?

15. Completion Checklist

Work down this list before you submit. Every line is graded.

15.1 Day 1

Done	Item
	Sections 4 and 5 read before touching the queue
	Triage log created with all seven columns from Section 3.2
	All twenty alerts have a decision recorded
	All twenty alerts have a confidence level recorded
	All twenty alerts have a written justification
	Runbook criterion cited for each decision
	Distance and required speed calculated by hand for all five impossible-travel alerts
	Every source address checked against the known ranges in Section 4.3
	Linked alerts column completed, not left empty
	Triage log sorted by account name and re-reviewed
	Escalation note written in the Section 7.1 format for every escalation
	Highest-urgency escalation has a first step phrased as a yes or no question
	Three least-confident closures each have a note saying what would change your mind
	Both genuinely ambiguous alerts identified and analysed
	Escalation count sanity-checked against the guidance in Section 6.5

15.2 Day 2

Done	Item
	Roles assigned and recorded, including who doubled up
	Attack chain reconstructed in order with the mechanism named at each step

Done	Item
	Initial access vector identified and what it yielded stated
	The multi-factor technique named
	Scope established, including what you checked to conclude it stops there
	What almost happened stated in one sentence
	What is still at risk stated
	What cannot be determined from available evidence noted
	All nine candidate actions considered, ordered or rejected with reasons
	The action that would damage the response identified and rejected explicitly
	Containment action log completed with timestamps and owners
	All five containment claims verified, with the verification method stated
	Improvement identified, specific, with its cost or inconvenience stated
	Merged timeline built, including the who-knew-at-the-time column
	Weakest hand-off identified and analysed
	Tier 1 correlation review answered honestly
	After-action report written with all eight sections from Section 11.4
	Executive summary written for a non-technical reader

Before you submit

Read your executive summary out loud. If a branch manager would need to ask you a follow-up question, rewrite it.

Check that every closure in your Day 1 log has reasoning, not just a decision.

Check that your containment log records the actions you rejected as well as the ones you took.

Appendix A: Reference and Troubleshooting

A.1 Impossible travel: the arithmetic, worked

Use this method on every impossible-travel alert. It takes about a minute and it is the whole decision.

STEP 1 Get the distance from the table in Section 4.7.
 STEP 2 Convert the elapsed time to hours.
 STEP 3 Required speed = distance in miles / elapsed time in hours.
 STEP 4 Compare against reality:
 under 75 mph -> ground travel explains it
 75 to 550 mph -> a flight could explain it, check for a travel record
 over 600 mph -> not physically possible, something else is going on

WORKED EXAMPLE, using MTB-B01:

Pittsburgh to Lagos = 5,578 miles
 Elapsed 47 minutes = 0.783 hours
 5,578 / 0.783 = 7,123 mph
 Verdict: roughly nine times the speed of an airliner. Not travel.

BEFORE YOU ESCALATE, ALWAYS CHECK:

Is either address inside 198.51.100.0/24 (corporate VPN egress)?
 If yes, the geolocation is an artefact of where our VPN exits,
 not a statement about where the person is.

A.2 Alert type quick reference

Type	The question that usually decides it
Failed login	One account or many? Many accounts from one source is a spray, and the attempt count per account will look low on purpose.
Impossible travel	Is either address the corporate VPN egress range? If not, do the speed arithmetic.
BEC indicator	Does the rule hide, delete or forward anything? Hiding financial keywords is compromise until proven otherwise.
Wire transfer	Is the beneficiary new, or did its bank details recently change? And is the initiating account in any other alert in the queue?

A.3 The five mistakes that cost marks on this lab

Mistake	What to do instead
Trusting the severity label on the alert	Severity is assigned by a rule before anyone looked at it. Two Low alerts in this queue deserve escalation and at least one High does not.
Trusting the words 'impossible travel' in the alert title	The title is the rule's guess. Do the arithmetic and check the VPN range yourself.
Treating any external-looking IP as hostile	Check Section 4.3 first. Our own VPN egress is a public address range.
Closing without writing anything down	An undocumented closure cannot be reviewed or defended. It is graded as if you had not worked the alert.

Mistake	What to do instead
Working the queue in order and never looking back	Sort by account name at the end. Alerts arrive separately; attacks do not.

A.4 If you get stuck

Problem	What to do
I cannot decide on an alert	Write down what would settle it and who you would ask. That is a legitimate Tier 1 output and it is worth marks. 'Escalating to Tier 2 because I need X and cannot get it at Tier 1' is a real decision.
I think I am escalating too much	Re-read your justifications. If a justification does not cite a specific runbook escalation criterion, that alert is a candidate for closure.
I think everything looks benign	Go back to the four wire alerts and the four alerts involving the same Treasury account. At least six alerts in this queue warrant escalation.
Two alerts seem to contradict each other	They may both be true and belong to the same incident. Put both alert IDs in each other's Linked alerts cell and say so in the escalation note.
I finished in an hour	You have probably not done the impossible-travel arithmetic or written closure justifications. Both are graded.
My team disagrees on Day 2 containment order	That disagreement is the exercise. Record both positions and the Incident Commander's decision. A documented disagreement is a better artefact than false consensus.

A.5 Working with an AI assistant

You may use an AI assistant on this lab. Use it the way a working analyst does.

- **Good use** - ask it to explain what SPF and DKIM are, what a push-notification fatigue attack is, or to review whether your escalation note reads clearly to someone who has not seen the alert.
- **Bad use** - pasting the queue in and asking which to escalate. You will get twenty confident answers and you will not be able to defend one of them, which is the entire assessment.
- **Never** - do not paste customer data, account numbers or personal data into an AI assistant. Everything in this lab is fabricated, so nothing here is real, but the habit is what matters. Week 7 Day 5 covers exactly why.

Cite it. If an AI helped you reach a conclusion, note where and what you did to verify it.